

Introduction to the SOC

Brian Olliff

Defensive Engineering Instructor

Key Concepts

- + SOC Operations
- + Attack mapping using frameworks
- + Working in a SOC

MAJOR TOPICS

- + What is a SOC?
- + Roles & staffing
- + Guides & frameworks
- + Common tools
- + DFIR



LEARNING OUTCOMES

- + Understand the role and purpose of a SOC
- + Be familiar with different positions and analyst tiers
- + Understand daily operations in a SOC
- + Understand how frameworks and other tools can assist
- + Be familiar with basics of digital forensics activity
- + Understand SOC maturity levels

PREREQUISITES

- + Basic cybersecurity fundamentals
- + Basic IT/networking fundamentals

Let's Get Started!

Introduction to the SOC

- + Beginning with understanding role and functions of a SOC

What is a SOC?



What is a Security Operations Center?

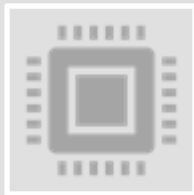
A dedicated unit or team that monitors and defends an organization's IT infrastructure.

Acts as the central command post for cybersecurity, staffed by security analysts.

Continuously tracks network, system, and application activities for signs of threats.

Combines people, processes, and technology to detect and respond to cyber attacks.

Central Hub of Operations



Coordinates all of the organization's cybersecurity monitoring and response efforts.



Focal point where data from various security tools and sources is collected and analyzed.



SOC team works closely with other IT and security teams, acting as the nerve center during security incidents.

SOC Threat Detection

1

Continuous monitoring of logs and events to identify suspicious activities or anomalies.

2

Security tools (like intrusion detection systems and SIEMs) generate alerts for potential threats.

3

Analysts investigate these alerts to determine if they indicate real security incidents.

4

Early detection is crucial – the sooner a threat is found, the faster it can be contained.

Need for a SOC

- Incidents can occur at any time
 - SOC provides 24/7 monitoring
- Dedicated SOC reduces time to detection
 - Faster threat is detected, faster can be remediated
- Structured, efficient incident response
- Some regulations & standards may require continuous monitoring
 - SOC assists with compliance and auditing requirements
- Can give org confidence that systems are protected

SOC Roles & Responsibilities



SOC Analysts

Tier 1

Tier 2

Tier 3

Tier 1 Analysts

First line of defense: continuously monitors security dashboards and alerts (e.g., SIEM alerts).

Performs initial triage to determine if an alert is legitimate or a false positive.

Resolves simple issues (false alarms, known benign events) and documents findings.

Escalates incidents to Tier 2 when deeper investigation or higher privileges are required.

Tier 2 Incident Responders



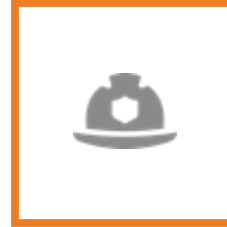
Investigates Escalated Alerts

Confirms if a security incident is occurring by analyzing Tier 1 escalated alerts



In-Depth Analysis

Performs comprehensive analysis to determine the scope and impact of the incident



Response Actions

Takes necessary response actions and starts remediation



Coordination with IT Staff

Collaborates with IT staff to resolve the incident and gather additional information

Tier 3 Threat Hunters & Forensics Experts

- Senior security experts
 - Handle most complex or advanced incidents
- Proactively hunts for threats (Threat Hunter)
 - Potential incidents that have not triggered alerts
- Perform deep forensic analysis
 - Used to determine root cause of attack
- Improve detection abilities of SOC
 - Develop new user cases
 - Tune security controls
 - Mentor junior analysts

Additional Roles/Functions

- Threat Intelligence Analyst: Focuses on external threat data (e.g., new hacker tactics, indicators of compromise) to inform the SOC team.
- SOC Engineer/Architect: Manages and fine-tunes the security tools (SIEM, IDS, etc.) and infrastructure that the SOC relies on.
- Incident Coordinator: In some SOC's, a role dedicated to managing communication and workflow during major incidents.
- Larger organizations might also have dedicated malware analysts, compliance specialists, or other support roles within the SOC.

SOC Manager

Leads the SOC team, ensuring 24/7 coverage and that procedures are followed correctly.

Oversees incident handling and provides guidance or approval for significant response actions.

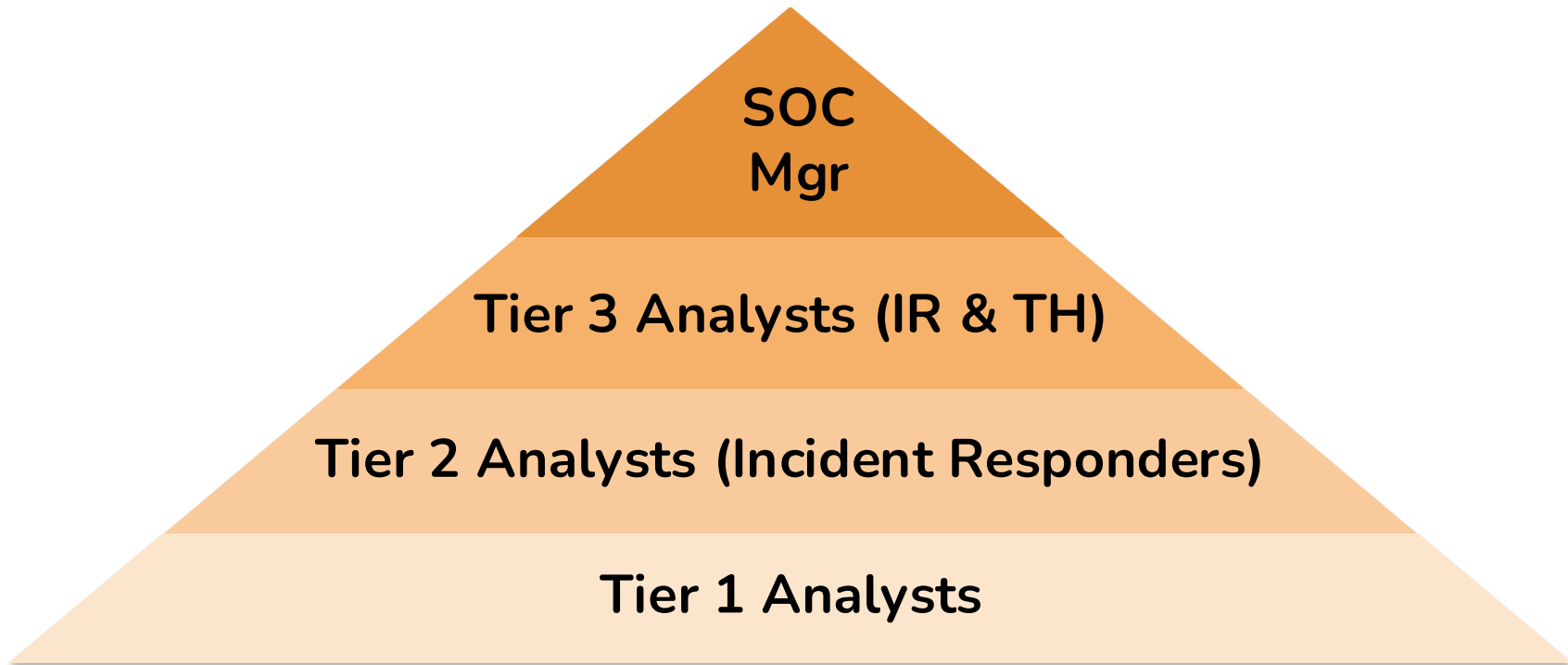
Tracks security metrics and reports on the SOC's performance

Responsible for staffing, training, and continual improvement of SOC operations and technologies.

SOC Operations



SOC Tiers



On-site SOC

Larger orgs often have an in-house SOC facility

Sensitive data and incident details stay within the organization's control

SOC team can be intimately familiar with the org's systems

Direct communication lines to other departments (IT, legal, management)

In-House vs Outsourced

In-house: operated by org employees

Outsourced (MSSP): offers SOC services remotely

Many orgs use hybrid solution

Orgs with highly sensitive/classified data often prefer in-house

24/7 SOC Operations

- Threats don't follow business hours
- Analysts rotate through shifts
- Structured handover between shifts
- 24/7 monitoring crucial for detecting attacks at early stages



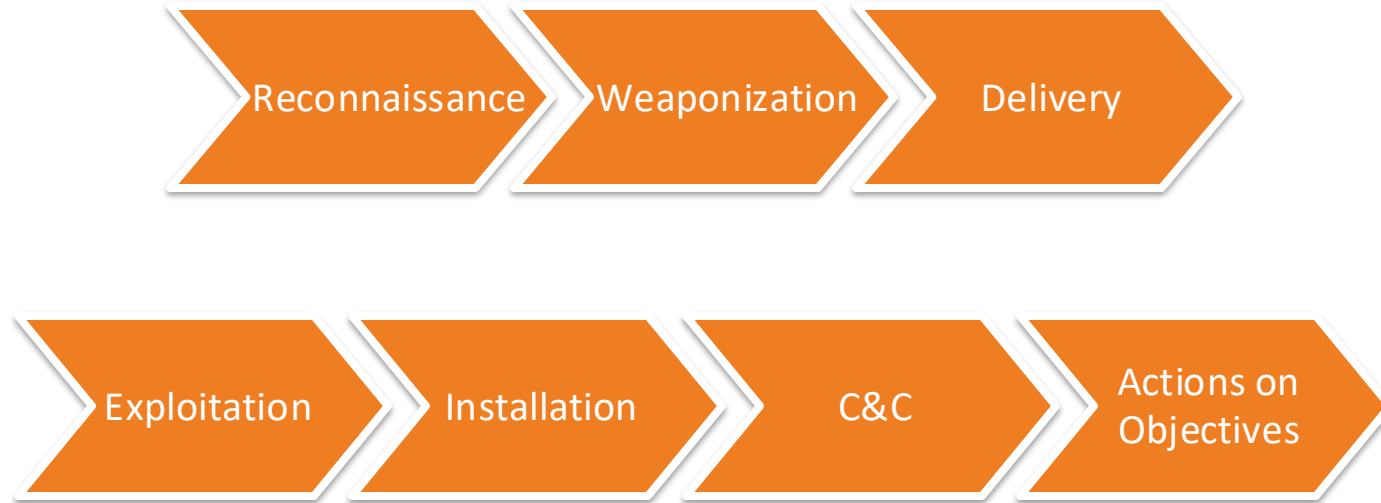
Global SOC

- Global monitoring is vital for organizations with worldwide presence
- Multinational organizations often operate multiple SOC's in different regions for global coverage
- "Follow-the-sun" approach
 - Incidents/monitoring responsibility passed to SOC in daytime hours
- Central SOC might coordinate with regional SOC's, sharing information across the globe

Cyber Kill Chain



Cyber Kill Chain



<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

Reconnaissance

- Attacker gathers information about target
- Passive and active methods
 - Internet searches
 - Email harvesting
 - Network scans



Weaponization

- Attacker creates deliverable payload
- May consist of
 - Remote access tool (RAT) or other backdoor
 - Encryption tools
 - Other malware downloader



Delivery

- Malicious payload sent to victim
 - Email
 - Watering hole attack (malicious website)
 - Drive-by download
 - Malicious USB drive



Exploitation

- Malicious payload is run on victim system
 - User opens email attachment
 - Visit to malicious website where malware downloads/runs
- Attacker may exploit other vulnerabilities using other methods
- Can be multi-step process
 - Original payload runs and downloads additional malware



Installation

- Additional tools installed via original RAT/backdoor
 - Encryption software
 - More complex malware
 - Command & control software
 - Exfiltration tools
- Any tools attacker needs to carry out objective



Command & Control

- Victim machine connects to attacker controlled infrastructure
 - May use well-known ports to evade firewall rules/detection
 - Traffic may be encrypted
- Allows additional commands and malware to be run
 - Attacker can further customize based on victim environment



Actions on Objectives

- Attacker accomplishes original goals based on all previous steps
 - Encryption and ransom demand
 - Data theft (and possible ransom)
 - Destruction of data or systems
 - Software disruption
 - Persistent access for further goals



NIST Cybersecurity Framework



NIST CSF

- National Institute of Standards and Technology
 - Part of US Department of Commerce
 - Develops standards, guidelines, frameworks
 - Created and maintains CSF
- Structure and language for managing cybersecurity risk
 - Designed to help orgs understand current and needed cybersec programs
 - Aligns cybersecurity with business goals
- Used by organizations worldwide - not just US

Five Core Functions

Function	Description
Identify	Understand assets, systems, and risks
Protect	Implementing access control, data security, and endpoint protection
Detect	Monitoring, detecting anomalies, and identifying threats
Respond	Containment, eradication, and mitigation of incidents
Recover	Restore operations, lessons learned, and continuous improvement

In Practice

- Potentially malicious email delivered to mailbox
 - **Detect** through user report/mailbox monitoring/etc
- Analyst investigates alert and escalates for remediation
 - **Respond**
- Indicators collected from email and added to filters
 - **Identify** and **Protect**
- Organization updates training for users
 - **Recover**
- Understanding helps analysts see whole picture beyond just alerts
 - Ability to communicate better
 - Tie metrics into organizational goals

MITRE ATT&CK



MITRE ATT&CK

- **A**dversarial **T**actics, **T**echniques, & **C**ommon **K**nowledge
- “Knowledge base of adversary tactics and techniques based on real-world observations”
- ATT&CK Matrix for Enterprise
 - Columns reflect tactics, which contain techniques
 - Over 230 techniques
 - Each contains explanation, procedure examples, mitigation, detection

ATT&CK Matrix

ATT&CK Matrix for Enterprise

layout: side ▾

show sub-techniques

hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
10 techniques	8 techniques	10 techniques	14 techniques	20 techniques	14 techniques	44 techniques	17 techniques	32 techniques	9 techniques	17 techniques	18 techniques	9 techniques	14 techniques
Active Scanning (2)	Acquire Access	Content Injection	Cloud Administration Command	Account Manipulation (7)	Abuse Elevation Control Mechanism (4)	Abuse Elevation Control Mechanism (4)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (3)	Automated Exfiltration (2)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (3)	Drive-by Compromise	Command and Scripting Interpreter (11)	BITS Jobs	Access Token Manipulation (3)	Access Token Manipulation (3)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Gather Victim Identity Information (3)	Compromise Accounts (2)	Exploit Public-Facing Application	Container Administration Command	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Account Manipulation (7)	Credentials from Password Stores (4)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Automated Collection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (8)	Compromise Infrastructure (3)	External Remote Services	Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Boot or Logon Autostart Execution (14)	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Content Injection	Browser Session Hijacking	Exfiltration Over C2 Channel	Data Manipulation (3)
Gather Victim Org Information (4)	Establish Accounts (2)	Hardware Additions	Exploitation for Client Execution	Browser Extensions	Boot or Logon Initialization Scripts (5)	Boot or Logon Initialization Scripts (5)	Forced Authentication	Cloud Service Dashboard	Remote Services (5)	Data Encoding (2)	Data Obfuscation (2)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Phishing for Information (4)	Obtain Capabilities (7)	Phishing (4)	Inter-Process Communication (3)	Compromise Host Software Binary	Create or Modify System Process (3)	Create or Modify System Process (3)	Forge Web Credentials (2)	Cloud Storage Object Discovery	Replication Through Removable Media	Data from Cloud Storage	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Search Closed Sources (2)	Stage Capabilities (4)	Replication Through Removable Media	Native API	Create Account (3)	Domain or Tenant Policy Modification (2)	Domain or Tenant Policy Modification (2)	Input Capture (4)	Container and Resource Discovery	Software Deployment Tools	Data from Configuration Repository (3)	Encrypted Channel (3)	Exfiltration Over Web Service (4)	Endpoint Denial of Service (4)
Search Open Technical Databases (5)		Supply Chain Compromise (2)	Scheduled Task/Job (3)	Create or Modify System Process (3)	Execution Guardrails (2)	Execution Guardrails (2)	Modify Authentication Process (4)	Debugger Evasion	Taint Shared Content	Data from Information Repositories (3)	Fallback Channels	Exfiltration Over Web Service (4)	Firmware Corruption
Search Open Websites/Domains (2)		Trusted Relationship	Serverless Execution	Event Triggered Execution (17)	File and Directory Permissions Modification (2)	File and Directory Permissions Modification (2)	Multi-Factor Authentication Interception	Device Driver Discovery	Use Alternate Authentication Material (4)	Data from Local System	Hide Infrastructure	Scheduled Transfer	Inhibit System Recovery
Search Victim-Owned Websites		Valid Accounts (4)	Shared Modules	Event Triggered Execution (17)	Hide Artifacts (12)	Hide Artifacts (12)	Multi-Factor Authentication Request Generation	Domain Trust Discovery		Data from Network Shared Drive	Ingress Tool Transfer	Transfer Data to Cloud Account	Network Denial of Service (3)
			Software Deployment Tools	External Remote Services	Hijack Execution Flow (13)	Hijack Execution Flow (13)	Network Sniffing	File and Directory Discovery		Data from Removable Media	Multi-Stage Channels		Resource Hijacking (4)
			System Services (2)	Hijack Execution Flow (13)	Impersonation	Impersonation	OS Credential Harvesting (4)	Group Policy Discovery		Data Transfer ...	Non-Application Layer Protocol		Service Stop
			User Execution (3)	Implant Internal Image	Process Search (4)	Process Search (4)		Log Enumeration			Non-Standard Port		System Shutdown/Reboot
			Windows Management Instrumentation					Network Service Discovery					
								Network's Share					

<https://attack.mitre.org>



Technique

Phishing

Sub-techniques (4) ▼

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the adversary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.

Adversaries may send victims emails containing malicious attachments or links, typically to execute malicious code on victim systems. Phishing may also be conducted via third-party services, like social media platforms. Phishing may also involve social engineering techniques, such as posing as a trusted source, as well as evasive techniques such as removing or manipulating emails or metadata/headers from compromised accounts being abused to send messages (e.g., [Email Hiding Rules](#)).^{[1][2]} Another way to accomplish this is by forging or spoofing^[3] the identity of the sender which can be used to fool both the human recipient as well as automated security tools,^[4] or by including the intended target as a party to an existing email thread that includes malicious files or links (i.e., "thread hijacking").^[5]

Victims may also receive phishing messages that instruct them to call a phone number where they are directed to visit a malicious URL, download malware,^{[6][7]} or install adversary-accessible remote management tools onto their computer (i.e., [User Execution](#)).^[8]

ID: T1566

Sub-techniques: [T1566.001](#), [T1566.002](#),
[T1566.003](#), [T1566.004](#)

① **Tactic:** [Initial Access](#)

① **Platforms:** Identity Provider, Linux, Office Suite, SaaS, Windows, macOS

Contributors: Liora Itkin; Liran Ravich, CardinalOps; Ohad Zaidenberg, @ohad_mz; Philip Winther; Scott Cook, Capital One

Version: 2.6

Created: 02 March 2020

Last Modified: 07 October 2024

[Version Permalink](#)



Importance for SOC Analysts

- Understand the “**why**” behind alerts
 - Gives context behind what may be happening
- Ability to clearly communicate in findings
 - Terms and IDs are standardized
 - Commonly used in SOC's
- Helps connect alerts to attacker goals
 - Understand the attack chain, not just single alerts
- Required knowledge for advancement to T2 or Threat Hunter roles

SOC Tools & Terminology



SOC Tools & Technology

SIEM: Aggregates logs and alerts, enabling correlation and centralized monitoring

Network Security Tools: Firewalls, IDS/IPS for network perimeter and internal traffic

Endpoint Security Tools: Antivirus and EDR agents on endpoints

Vulnerability scanners, threat intelligence feeds, and case management systems

Monitoring Data Sources

Network Logs

Firewall, router, and switch logs provide insight into traffic patterns and potential intrusions

System Logs

Operating system and server application logs (login events, file access, errors) help detect suspicious behavior on hosts

Endpoint Reports

Alerts from antivirus & EDR software about malware or unusual activities on workstations and servers

Cloud Service Logs

Monitoring data from cloud platforms for unauthorized access or config issues

All sources feed into SOC tools (SIEM) for centralized analysis.

Security Information and Event Management

Core platform of
the SOC
Collects logs and
events from across
the organization.

Analysts use SIEM
dashboard to get
overview of
security alerts and
analyze log details
during investigation

Correlates data to
highlight suspicious
patterns

SIEM can generate
reports and
metrics.
Can provide a
central console for
incident tracking

Network Security Monitoring

1

Intrusion Detection Systems (IDS) monitor network traffic for known threat signatures or unusual patterns and alert the SOC of potential intrusions.

2

Intrusion Prevention Systems (IPS) go a step further by actively blocking suspicious traffic in real time.

3

These tools can detect things like port scans, exploit attempts, or malicious payloads traveling over the network.

4

SOC analysts investigate IDS/IPS alerts to verify attacks and adjust rules to reduce false positives while staying vigilant for new threats.

Threat Intelligence

- SOC tools often integrate threat intel feeds
 - Known malicious IPs, hashes, domains, etc
 - Can help with detecting known threats
- Analysts use threat intel to enrich alerts
 - Ex: recognizing that an IP flagged in alert is on known malicious list
- Using threat intel, SOC can proactively adjust defenses
 - Allows for prioritizing alerts based on current threat trends.

Incident Tracking & Collaboration

SOCs use ticketing or case management systems to document each incident from detection through resolution.

These tools ensure hand-offs between shifts or team members are smooth, with all investigation notes recorded in one place.

Collaboration platforms are used during incidents to keep everyone synchronized.

Detailed tracking and communication help prevent things from falling through the cracks, especially during complex or long-running incidents.

Introduction to DFIR

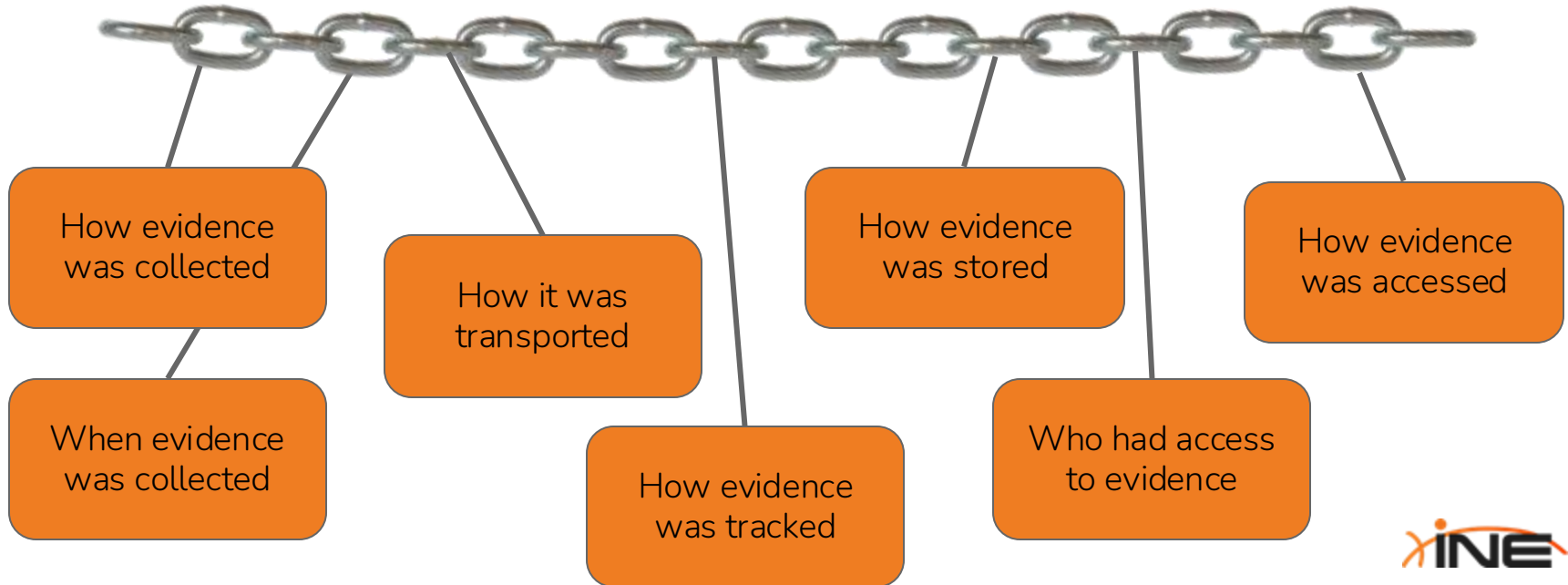


Digital Forensics

- Identification, collection, examination, and analysis of data
 - Evidence
 - Data can come from any type of device
 - Frequently used for legal purposes (in court of law)
- Requires preservation of evidence integrity
 - Strict chain of custody
- Often included in incident response activities
 - DFIR - digital forensics and incident response
- Attribution - identifying origin or source of attack
 - Can be very difficult to accomplish during investigation

Chain of Custody

- Documentation of evidence collection
 - From moment forensics investigation begins until presented in court



Digital Forensics in the SOC

Forensic analysis involves collecting and examining digital evidence from computers, servers, or networks after an incident.



SOC analysts may retrieve disk images, memory dumps, or log files from affected systems to investigate what happened.



Forensics can reveal the attack timeline, methods used by the attacker, and exactly what data or systems were impacted.



The findings help in understanding the incident fully and can be used for strengthening defenses or for legal proceedings if needed.

SOC

Maturity Levels



SOC Maturity

- Methods to define capability, effectiveness, and operational maturity
- SOC capabilities evolve based on
 - Security needs
 - Available resources
 - Risk tolerance

Why Maturity Matters

- Ensures scalability and adaptability to evolving cyber threats.
- Reduces incident response time and enhances detection capabilities.
- Aligns SOC operations with industry best practices and compliance standards.
- Helps organizations measure progress and identify gaps in security operations.
- Important to understand even as T1 Analyst

Maturity Model Example

Maturity Level	Description	Key Characteristics
Level 1 - Minimal (Ad-hoc)	No formal SOC	No 24/7 monitoring, security is reactive
Level 2 - Developing (Reactive)	Basic SOC	Monitoring exists, lacks automation or proactive measures. Mostly manual processes
Level 3 - Defined (Operational)	Established SOC	Incidents are detected, triaged, and handled systematically
Level 4 - Managed (Proactive)	Advanced SOC	Incorporates threat intel, analytics, automation, and threat hunting
Level 5 - Optimized (Intel-driven)	Fully integrated & automated SOC	Uses AI/ML-driven detection, automated responses

Introduction to the SOC - Summary

Key Concepts - Recap

- + SOC Operations
- + Attack mapping using frameworks
- + Working in a SOC



Learning Outcomes Recap

- + Understand the role and purpose of a SOC
- + Be familiar with different positions and analyst tiers
- + Understand daily operations in a SOC
- + Understand how frameworks and other tools can assist
- + Be familiar with basics of digital forensics activity
- + Understand SOC maturity levels

Next Steps

- + Continue with SOC Analyst Level 1 learning path
- + Additional courses on security basics
- + Research and practice with MITRE ATT&CK tools
- + Labs in Skill Dive

Thank you!

Introduction to the SOC

- + Thank you for your time!

EXPERTS AT MAKING YOU AN EXPERT

